

EE-482: Network Security and Cryptography

LECTURE NO 1: *Introduction*

Engr. Tehseen Ahsan

**Assistant Professor, Computer Engineering Department
HITEC University Taxila Cantt, Pakistan**

Organization of Lecture

1. Introduction
2. Security Goals
3. Cryptographic Attacks
4. Services and Mechanisms
5. Techniques

1. Introduction

- We are living in the information age. We need to keep information about every aspect of our lives. In other words, information is an asset that has a value like any other asset. As an asset, information needs to be secured from attacks.
- To be secured, information needs to be hidden from unauthorized access (*confidentiality*), protected from unauthorized change (*integrity*), and available to an authorized entity when it is needed (*availability*).

2. Security Goals (1 / 4)

- Let us first discuss three security goals: *confidentiality*, *integrity*, and *availability* (Figure 1).

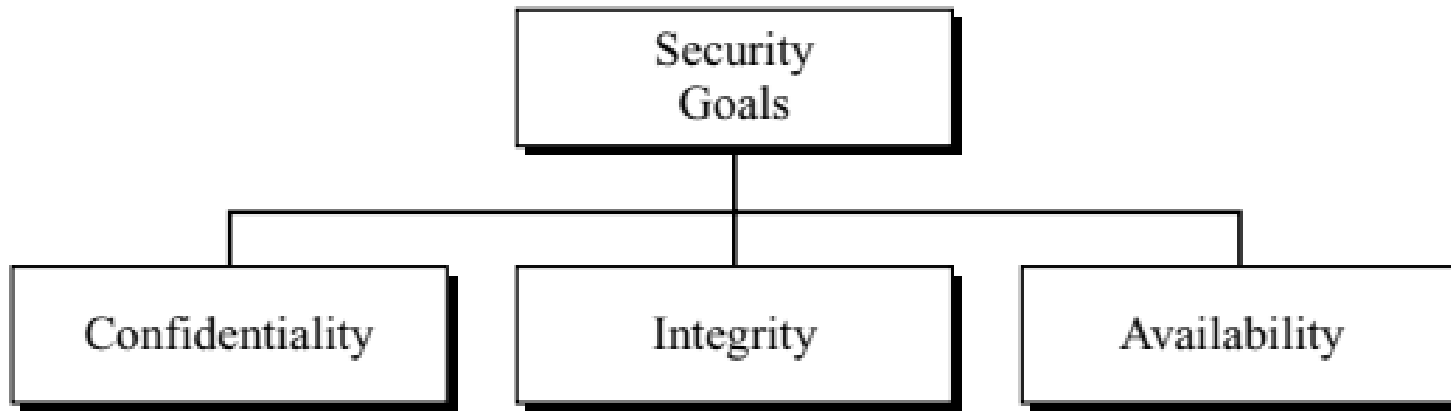


Figure 1: Taxonomy of security goals

2. Security Goals (2/4)

Confidentiality

- Confidentiality is probably the most common aspect of information security. We need to protect our confidential information. In the military, concealment of sensitive information is the major concern. In banking, customers' accounts need to be kept secret.
- *Confidentiality not only applies to the storage of the information, it also applies to the transmission of information.* When we send a piece of information to be stored in a remote computer or when we retrieve a piece of information from a remote computer, we need to conceal it during transmission.

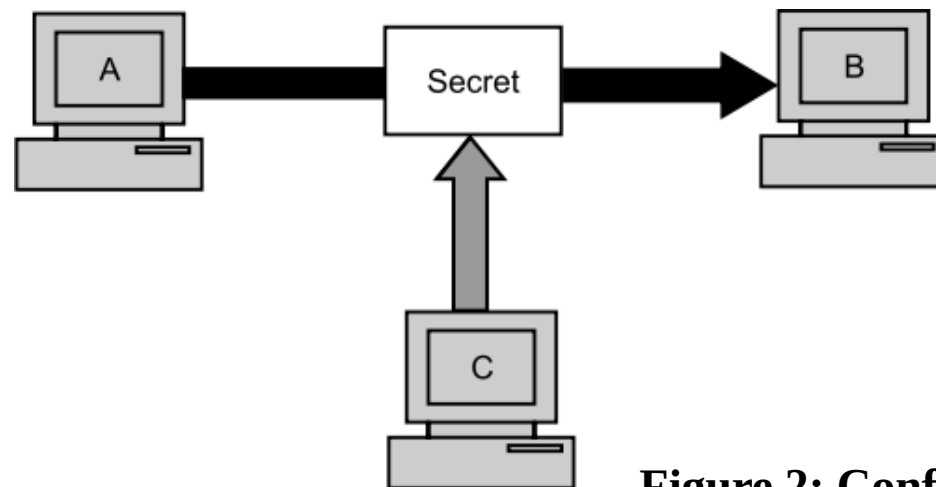


Figure 2: Confidentiality

2. Security Goals (3/4)

Integrity

- Information needs to be changed constantly. In a bank, when a customer deposits or with-draws money, the balance of her account needs to be changed. *Integrity means that changes need to be done only by authorized entities and through authorized mechanisms.* Integrity violation is not necessarily the result of a malicious act; an interruption in the system, such as a power surge, may also create unwanted changes in some information.

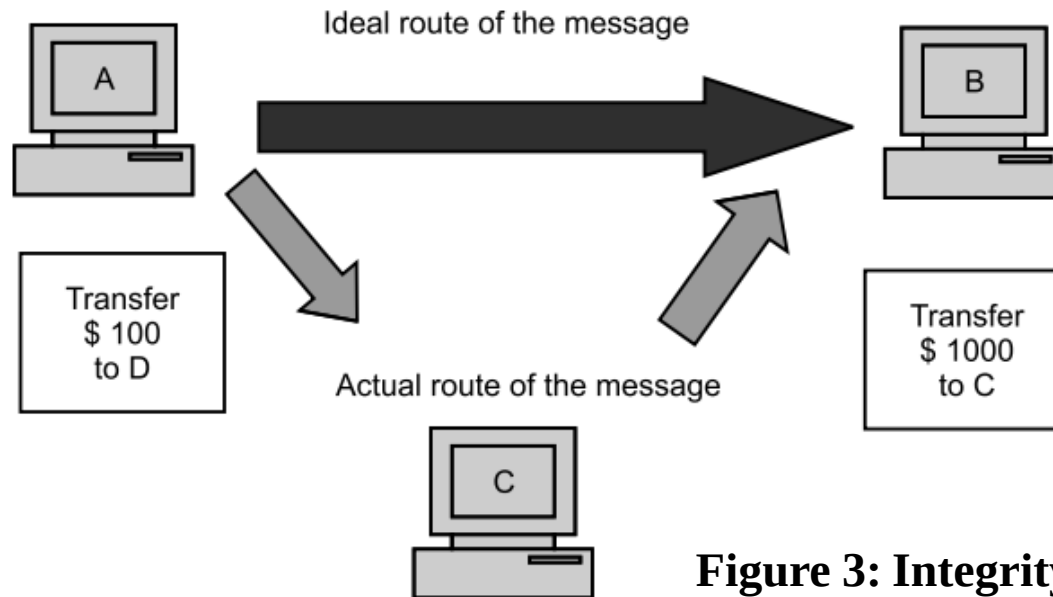


Figure 3: Integrity

2. Security Goals (4/4)

Availability

- The third component of information security is availability. *The information created and stored by an organization needs to be available to authorized entities. Information is use-less if it is not available.*
- The unavailability of information is just as harmful for an organization as the lack of confidentiality or integrity. Imagine what would happen to a bank if the customers could not access their accounts for transactions.

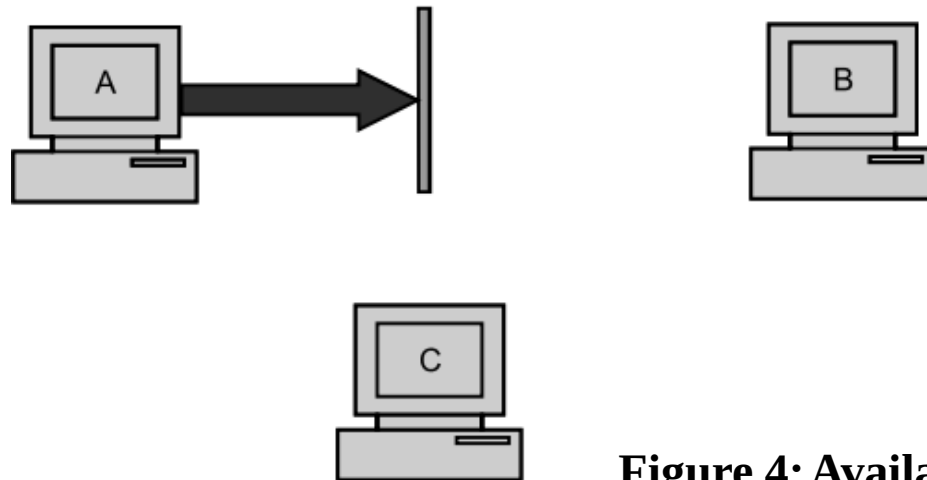


Figure 4: Availability

3. Cryptographic Attacks (1/8)

- Cryptographic attacks can be broadly categorized into two distinct types: 1. *Cryptanalytic* and 2. *Non-cryptanalytic*.

1. Cryptanalytic- The primary goal of Cryptanalytic attacks is to deduce the key. Find the crypto variable, the key, that can be used to decrypt the ciphertext.

3. Cryptographic Attacks (2/8)

2. Non-cryptanalytic- The other types of attacks are the attacks which do not exploit the mathematical weakness of the cryptographic algorithm (cryptanalytic attacks). However the three goals of security, namely confidentiality, integrity and availability can be very much threatened by this class of attacks. We divide the non-cryptanalytic attacks into three groups related to the security goals. Later, we will divide them into two broad categories based on their effects on the system. Figure 5 shows the first taxonomy.

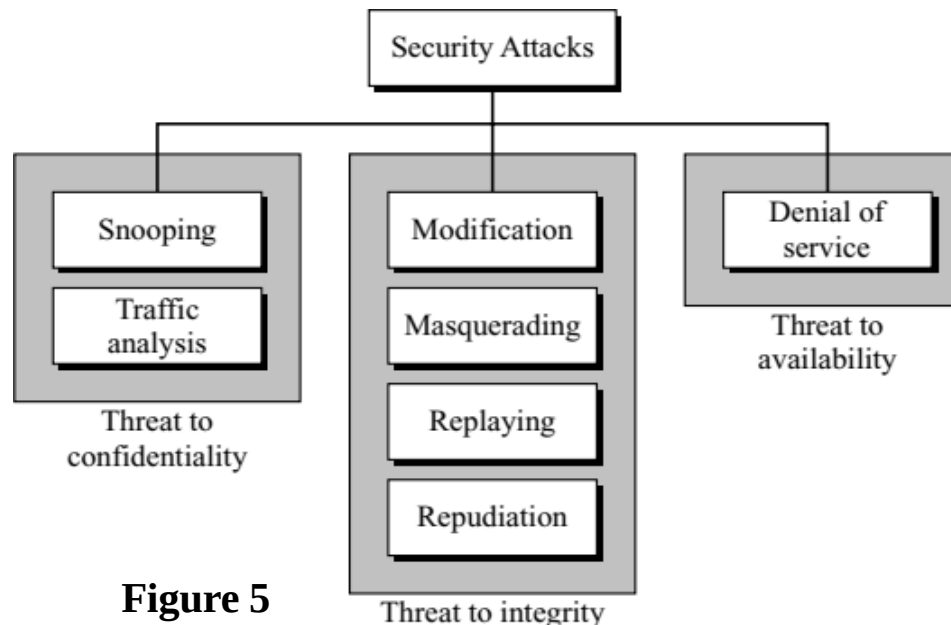


Figure 5

3. Cryptographic Attacks (3/8)

Attacks Threatening Confidentiality

- In general, two types of attacks threaten the confidentiality of information: *snooping* and *traffic analysis*.
- *Snooping*- refers to unauthorized access to or *interception* of data. For example, a file transferred through the Internet may contain confidential information. An unauthorized entity may intercept the transmission and use the contents in a message for her own benefits. To prevent snooping, the data can be made non-intelligible to the interceptor by using encipherment(encryption) techniques.
- *Traffic analysis*- Although encipherment of data may make it non-intelligible for the interceptor, she can obtain some other type of information by monitoring online traffic. For example, she can find the electronic address (such as the e-mail address) of the sender or the receiver. She can collect pairs of requests and responses to help her guess the nature of transaction.

3. Cryptographic Attacks (4/8)

Attacks Threatening Integrity

- The integrity of data can be threatened by several kinds of attacks: *modification*, *masquerading*, *replaying*, and *repudiation*.
- *Modification*- After intercepting or accessing information, the attacker modifies the information to make it beneficial to herself. For example, a customer sends a message to a bank to do some transaction. The attacker intercepts the message and changes the type of transaction to benefit herself.
- *Masquerading*- Masquerading, or spoofing, happens when the attacker impersonates somebody else. For example, an attacker might steal the bank card and PIN of a bank customer and pretend that she is that customer while using an ATM.
- *Replaying*- also called *repeat attack* or *playback attack*, involves capture of a data unit and its subsequent retransmission to produce unauthorized effect.

3. Cryptographic Attacks (5/8)

Attacks Threatening Integrity

- **Repudiation-** This type of attack is different from others because it is performed by one of the two parties in the communication: the sender or the receiver. The sender of the message might later deny that she has sent the message; the receiver of the message might later deny that he has received the message.
- An example of denial by the sender would be a bank customer asking her bank to send some money to a third party but later denying that she has made such a request.

3. Cryptographic Attacks (6/8)

Attacks Threatening Availability

- We mention only one attack threatening availability: *denial of service (DoS)*.
- Denial of service (DoS) is a very common attack. It may slow down or totally interrupt the service of a system. The attacker can use several strategies to achieve this. She might send so many bogus requests to a server that the server crashes because of the heavy load. The attacker might intercept and delete a server's response to a client, making the client to believe that the server is not responding. The attacker may also intercept requests from the clients, causing the clients to send requests many times and overload the system.

3. Cryptographic Attacks (7/8)

Passive Versus Active Attacks

- Let us now categorize the attacks into two groups: *passive* and *active*. Table 1 shows the relationship between this and the previous categorization.

Table 1 *Categorization of passive and active attacks*

<i>Attacks</i>	<i>Passive/Active</i>	<i>Threatening</i>
Snooping Traffic analysis	Passive	Confidentiality
Modification Masquerading Replaying Repudiation	Active	Integrity
Denial of service	Active	Availability

3. Cryptographic Attacks (8/8)

Passive Versus Active Attacks (continued...)

- In a **passive attack**, the attacker's goal is just to obtain information. This means that the attack does not modify data or harm the system. Attacks that threaten confidentiality-snooping and traffic analysis are passive attacks. They are difficult to detect, however they can be prevented by encipherment of the data.
- An **active attack** may change the data or harm the system. Attacks that threaten the integrity and availability are active attacks. Active attacks are normally easier to detect than to prevent, because an attacker can launch them in a variety of ways.

4. Services and Mechanisms (1/8)

- The International Telecommunication Union-Telecommunication Standardization Sector (ITU-T) provides some security services and some mechanisms to implement those security services. Security services and mechanisms are closely related because a mechanism or combination of mechanisms are used to provide a security service.

Security Services

- ITU-T (X.800) has defined five security services related to the security goals and attacks. Figure 6 shows the taxonomy of those five common services.

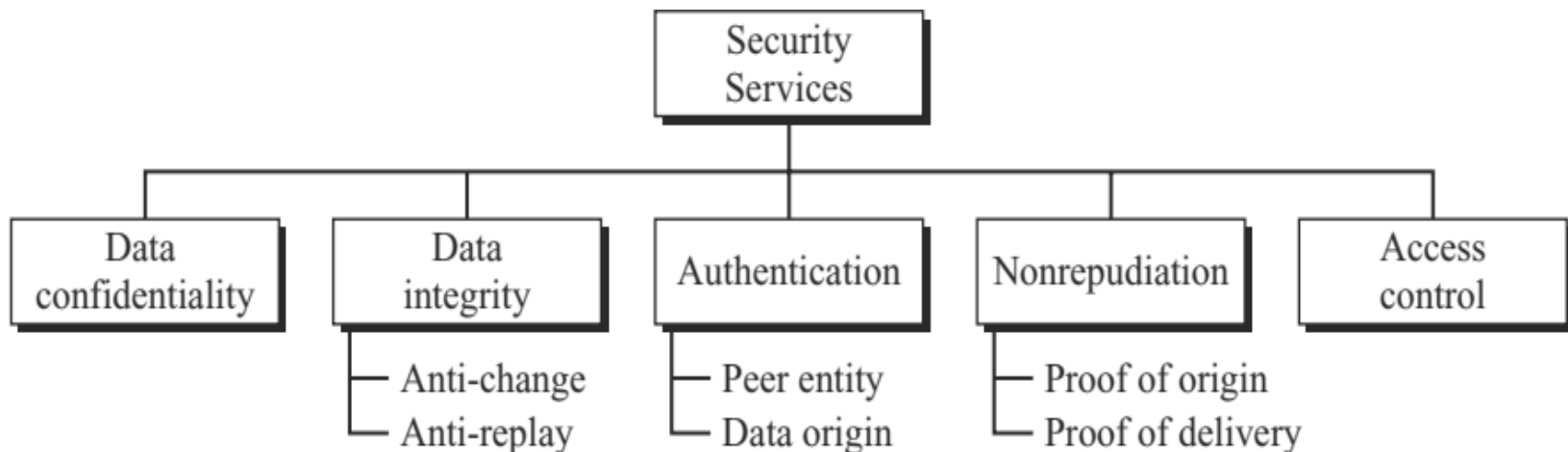


Figure 6

4. Services and Mechanisms (2/8)

Data Confidentiality

- Data confidentiality is designed to protect data from disclosure attack. The service as defined by X.800 is very broad and encompasses confidentiality of the whole message or part of a message and also protection against traffic analysis. That is, it is designed to prevent snooping and traffic analysis attacks.

Data Integrity

- Data integrity is designed to protect data from modification, insertion, deletion, and replaying by an adversary. It may protect the whole message or part of the message.

Authentication

- This service provides the authentication of the party at the other end of the line. In connection-oriented communication, it provides authentication of the sender or receiver during the connection establishment (*peer entity authentication*). In connectionless communication, it authenticates the source of the data (*data origin authentication*).

4. Services and Mechanisms (3/8)

Non-repudiation

- Non-repudiation service protects against repudiation by either the sender or the receiver of the data. In nonrepudiation, with *proof of the origin*, the receiver of the data can later prove the identity of the sender if denied. In nonrepudiation, *with proof of delivery*, the sender of data can later prove that data were delivered to the intended recipient.

Access Control

- Access control provides protection against unauthorized access to data. The term access in this definition is very broad and can involve reading, writing, modifying, executing programs, and so on.

4. Services and Mechanisms (4/8)

Security Mechanisms

- ITU-T (X.800) also recommends some security mechanisms to implement the security services. Figure 7 gives the taxonomy of these mechanisms.

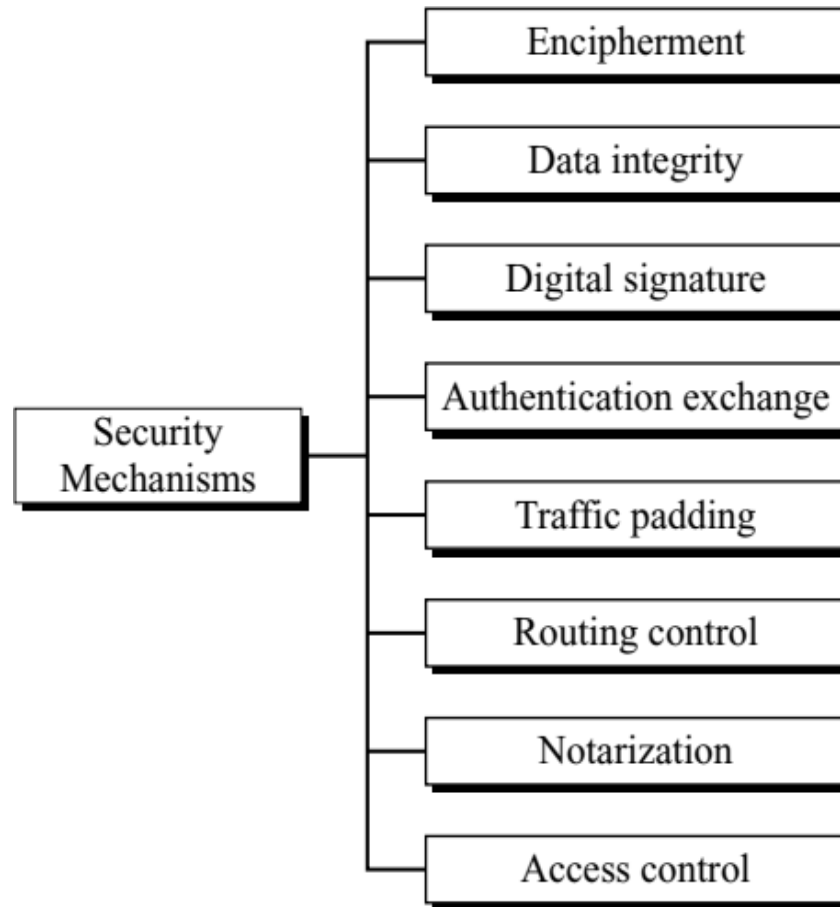


Figure 7

4. Services and Mechanisms (5/8)

Encipherment

- Encipherment, hiding or covering data, can provide confidentiality. Today two techniques i.e., cryptography and steganography are used for enciphering.

Data Integrity

- The data integrity mechanism appends to the data a short checkvalue that has been created by a specific process from the data itself. The receiver receives the data and the checkvalue. He creates a new checkvalue from the received data and compares the newly created checkvalue with the one received. If the two checkvalues are the same, the integrity of data has been preserved. integrity is designed to protect data from modification, insertion, deletion, and replaying by an adversary. It may protect the whole message or part of the message.

4. Services and Mechanisms (6/8)

Digital Signature

- A digital signature is a means by which the sender can electronically sign the data and the receiver can electronically verify the signature.

Authentication Exchange

- In authentication exchange, two entities exchange some messages to prove their identity to each other.

Traffic Padding

- Traffic padding means inserting some bogus data into the data traffic to prevent the adversary's attempt to use the traffic analysis.

Routing Control

- Routing control means selecting and continuously changing different available routes between the sender and the receiver to prevent the opponent from eavesdropping on a particular route.



4. Services and Mechanisms (7/8)

Notarization

- Notarization means selecting a third trusted party to control and store the communication between two entities. This can be done, for example, to prevent repudiation.

Access Control

- Access control uses methods to prove that a user has access right to the data or resources owned by a system. Examples of proofs are passwords and PINs.

4. Services and Mechanisms (8/8)

Relation between Services and Mechanisms

- Table 2 shows the relationship between the security services and the security mechanisms.

<i>Security Service</i>	<i>Security Mechanism</i>
Data confidentiality	Encipherment and routing control
Data integrity	Encipherment, digital signature, data integrity
Authentication	Encipherment, digital signature, authentication exchanges
Nonrepudiation	Digital signature, data integrity, and notarization
Access control	Access control mechanism

5. TECHNIQUES (1/5)

- Mechanisms are only theoretical recipes to implement security services. The actual implementation of security services needs some techniques. Two techniques are prevalent today: one is very general (cryptography) and one is specific (steganography).

Cryptography

- Cryptography, a word with Greek origins, means “secret writing.” However, we use the term to refer to the science and art of transforming messages to make them secure and immune to attacks. Although in the past *cryptography* referred only to the encryption and decryption of messages using secret keys, today it is defined as involving three distinct mechanisms: symmetric-key encipherment, asymmetric-key encipherment, and hashing.

5. TECHNIQUES (2/5)

Cryptography (continued...)

- In **symmetric-key encipherment** (sometimes called secret-key encipherment or secret-key cryptography), an entity, say **Alice**, can send a message to another entity, say **Bob**, over an insecure channel with the assumption that an adversary, say **Eve**, cannot understand the contents of the message by simply eavesdropping over the channel. Alice encrypts the message using an encryption algorithm; Bob decrypts the message using a decryption algorithm. Symmetric-key encipherment uses a **single (shared) secret key** for both encryption and decryption. Encryption/decryption can be thought of as electronic locking. In symmetric-key enciphering, Alice puts the message in a box and locks the box using the shared secret key; Bob unlocks the box with the same key and takes out the message.

5. TECHNIQUES (3/5)

Cryptography (continued...)

- In **asymmetric-key encipherment** (sometimes called public-key encipherment or public-key cryptography), we have the same situation as the symmetric-key encipherment, with a few exceptions. First, there are two keys instead of one: **one public key** and **one private key**. To send a secured message to Bob, Alice first encrypts the message using Bob's public key. To decrypt the message, Bob uses his own private key.
- In **hashing**, a fixed-length message digest is created out of a variable-length message. The digest is normally much smaller than the message. To be useful, both the message and the message digest must be sent to Bob. Hashing is used to provide checkvalues, which were discussed earlier in relation to providing data integrity.

5. TECHNIQUES (4/5)

Steganography

The word *steganography*, with origin in Greek, means “covered writing,” in contrast with cryptography, which means “secret writing.” Cryptography means concealing the contents of a message by enciphering; steganography means concealing the message itself by covering it with something else. *Example of steganography is given in next slide.*

5. TECHNIQUES (5/5)

Dear George

Greetings to all at Oxford. Many thanks for your letter and for the Summer examination package.

All entry forms and fees forms should be ready for final dispatch to the Syndicate by Friday 20th or at the very least, by the 21st.

There is, however still room for improvement. Just give us two or three years and we will really show you. Please don't let the proposals destroy your basic O and A patterns. Certainly this sort of change, if implemented immediately, would bring disaster.

Hidden Message: your package ready friday 21st room three. Please destroy this immediately disaster

References: Textbooks

1. *“Cryptography and Network Security”, by Behrouz A. Forouzan, Debdeep Mukhopadhyay, 2nd Edition, McGraw Hill Education (India) Private Limited.*
2. *“Cryptography and Network Security Principles and Practice”, by William Stallings, 6th Edition, Pearson.*
3. *“Computer Security Principles and Practice”, by William Stallings, Lawrie Brown, 4th Edition, Pearson.*